Часть 1. Разведка и атака

1. **Изучение функций приложения**

   Изучите веб-интерфейс приложения вручную. Проверьте разделы меню, формы входа, регистрации, поиска. Посмотрите карточки товаров, представленные на главной странице.

   1. Форма отзывы клиентов
   2. Форма для обратной отправки яблочной выжимки
   3. Ссылка на гидхаб с кодом
   4. Коммент от admin@juice-sh.op - возможно мэйл админа
   5. Строка поиска
   6. Страница аутентификации

   Используя инструменты разведки (gobuster, dirb или другие), найдите открытые эндпоинты приложения. Отметьте наиболее критичные эндпоинты с точки зрения реализации атак.

   Dirb, Nikto - дало результаты, curl и ffuf - дало огромное количество директроий, копаться в них будет долго и скорее всего малорезультативно

   .

Эндпоинт	Для чего используется	Возможная атака и степень риска при реализации атаки
http://10.11.0.8:3000/public#/	Главная страница	Собственно поиски по ней входных точек и анализ
http://10.11.0.8:3000/ftp/	Архив какой то	Есть файл с пользователями и их ролями, есть файлы с кодами JS, файлы с отчетами ошибок, в общем то достаточно, в нашем случае интересен файл с именами и ролями - bruteforce

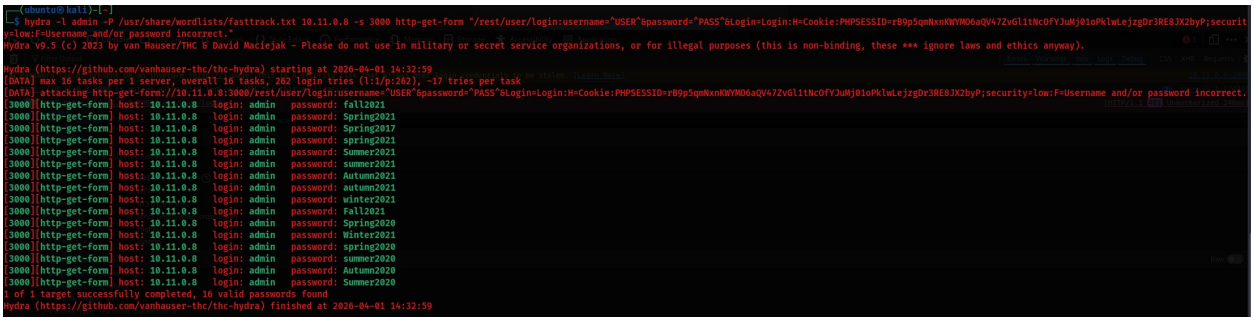
2. **Поиск и эксплуатация уязвимостей**

Выясните логин администратора. Реализуйте простую SQL-инъекцию через форму входа, чтобы получить доступ к его учётной записи.

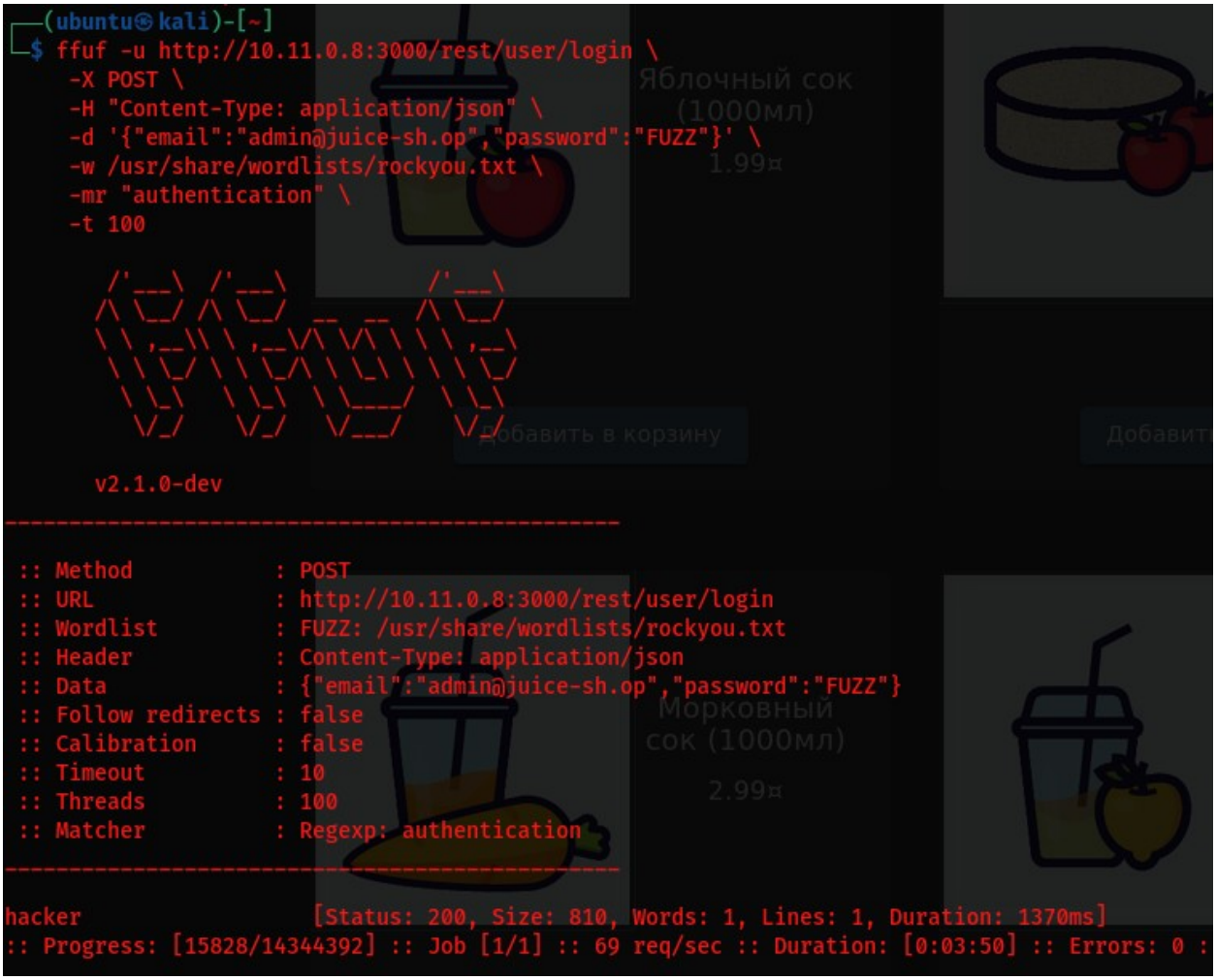


Реализуйте брутфорс-атаку на пароль администратора.

Как бы я не старался гидра не дала результата, пришлось искать



Использовал команду ffuf поскольку, чат гпт подсказал что get не работает на juice shop, с синтаксисом вроде разобрался, пароль hacker.



Любым способом получите список всех зарегистрированных пользователей приложения. Это может быть легальный HTTP-запрос, SQL-инъекция или другой метод.

-

```
  email: admin
  role: 'admin'
-
  email: jim
  role: 'customer'
-
  email: bender
  role: 'customer'
-
  email: bjoern.kimminich@gmail.com
  role: 'admin'
-
  email: ciso
  role: 'deluxe'
-
  email: support
  role: 'admin'
-
  email: morty
  role: 'customer'
-
  email: mc.safesearch
  role: 'customer'
-
  email: J12934
  role: 'admin'
-
```

```
  email: wurstbrot
  role: 'admin'
-
  email: amy
  role: 'customer'
-
  email: bjoern
  role: 'admin'
-
  email: bjoern@owasp.org
  role: 'deluxe'
-
  email: chris.pike
  role: 'customer'
-
  email: accountant
  role: 'accounting'
-
  email: uvogin
  role: 'customer'
-
  email: demo
  role: 'customer'
-
  email: john
  role: 'customer'
-
```

email: emma

role: 'customer'

-

email: stan

role: 'deluxe'

-

email: ethereum

role: 'deluxe'

-

email: testing

role: 'admin'

-

email: practicum

role: 'admin'

Выберите и проведите атаку, отличную от двух предыдущих. В отчёте опишите, как вы её реализовали, и последствия для работы приложения, если атака будет успешной.

В строке поиска реализована XSS атака <iframe src="javascript:alert(`xss`)"> - выполняется произвольный код. Последствия - фишинг, украденные данные и тд

Часть 2. Анализ и защита

3. **Сопоставление атак с матрицей MITRE ATT&CK**

Соотнесите реализованные ранее атаки с матрицей. Укажите тактику и технику для каждой из атак. Напишите все способы противодействия и отметьте среди них те, что применимы к приложению. Если способ защиты нельзя применить к приложению, поставьте в таблице прочерк.

Заполните таблицу после анализа угроз.

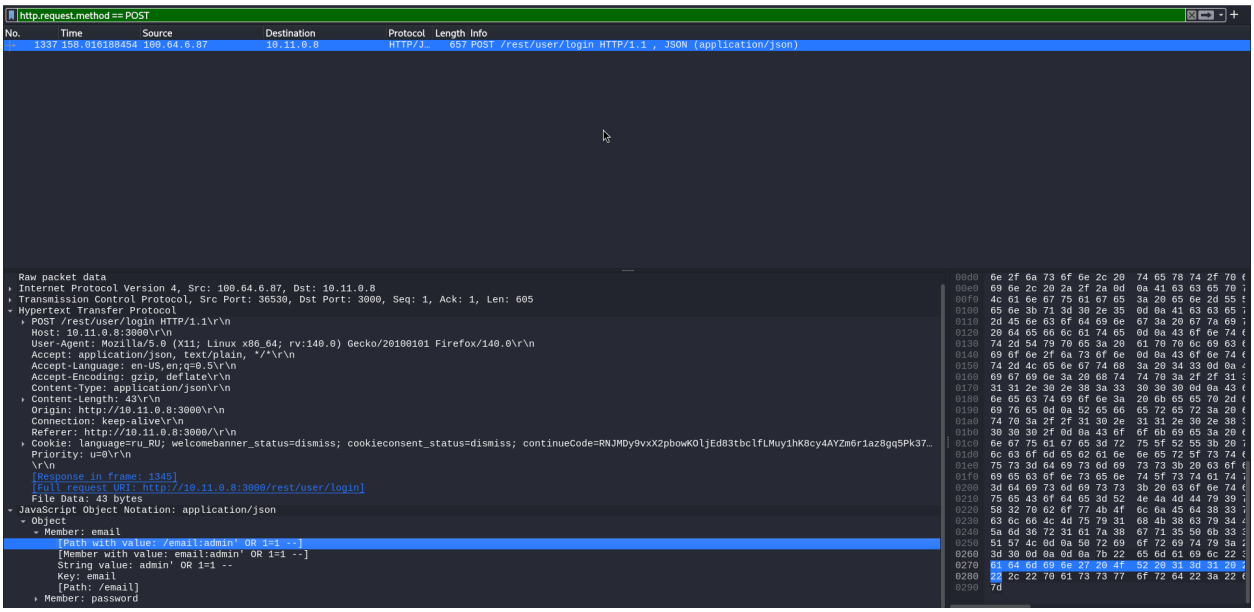
Атака	Тактика и техника по MITRE	Методы борьбы	Можно ли применить способ защиты к приложению «Сок и фрукты»
SQL-Injection	**T1190: Недостатки в общедоступном приложении**	Поиск уязвимостей, Управление привилегированными учетными записями, Сегментация сети, Защита от эксплойтов	Проверка на ввод в строку поиска
Bruteforce	**T1110.001: Угадывание пароля**	Парольные политики, Многофакторная аутентификация, Политики использования учетных записей, Обновление ПО	Можно установить число попыток на ввод
XSS	**T1659: Внедрение контента**	Ограничения для веб-контента, Шифрование важной информации	Проверка на ввод в строку поиска

4. Анализ дампа сетевого трафика

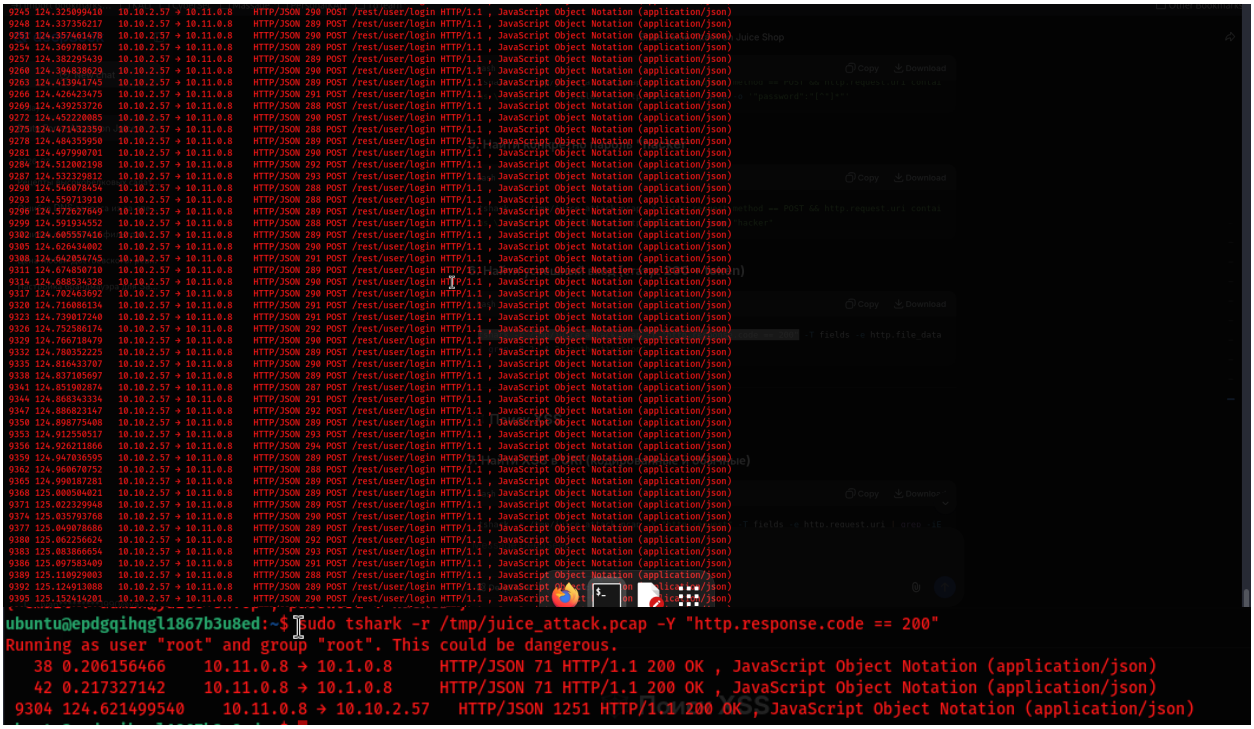
Запустите Wireshark или другую программу для анализа сетевого трафика и повторите все совершённые ранее атаки. После этого остановить перехват трафика и изучите полученный дамп.

Для каждой атаки укажите паттерны, которые их характеризуют.

SQL injection явно в строке



Большое число запросов с одного адреса, только один с кодом 200



Часть 3. Устранение уязвимостей

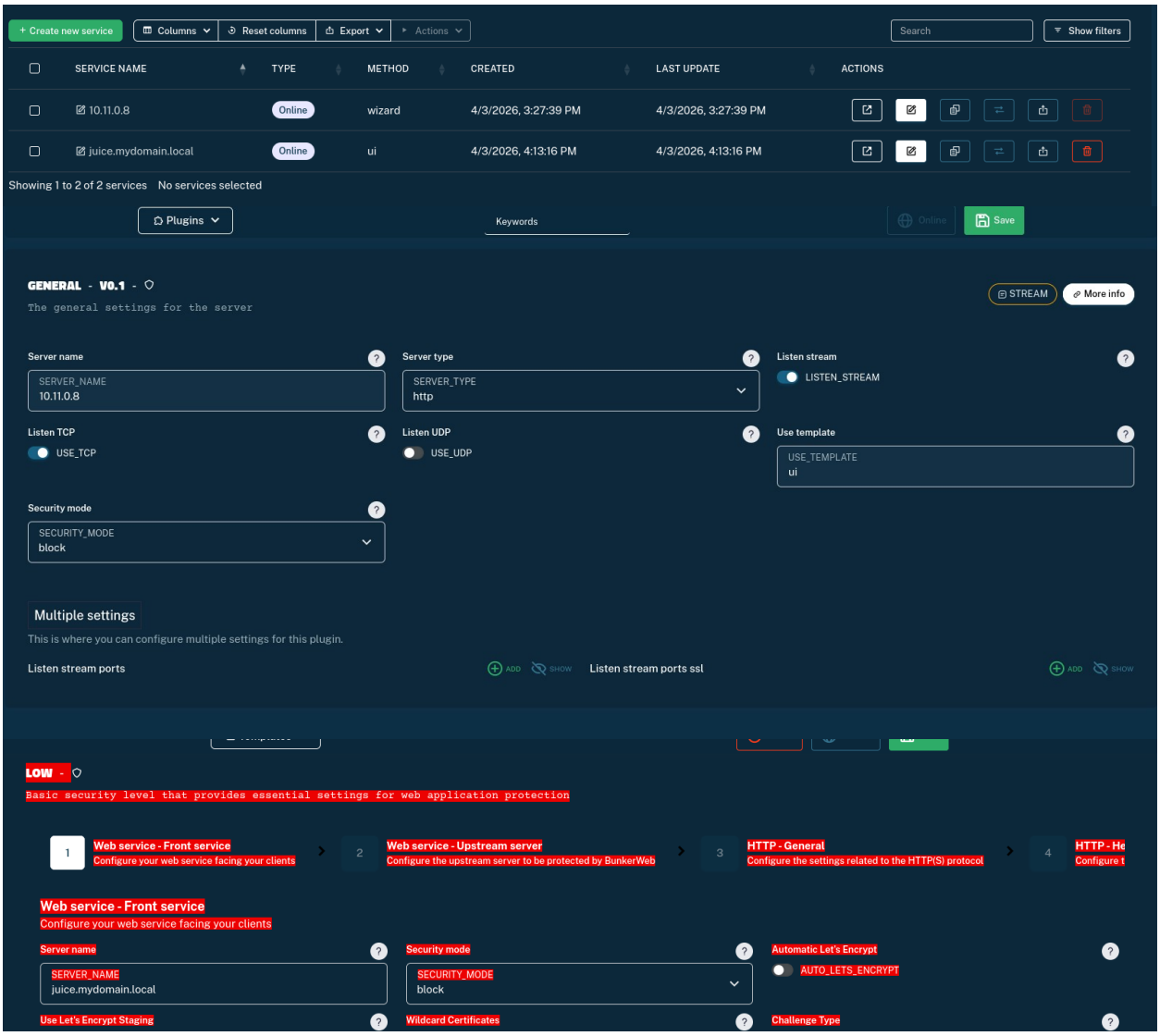
5. Устранение SQL-инъекции

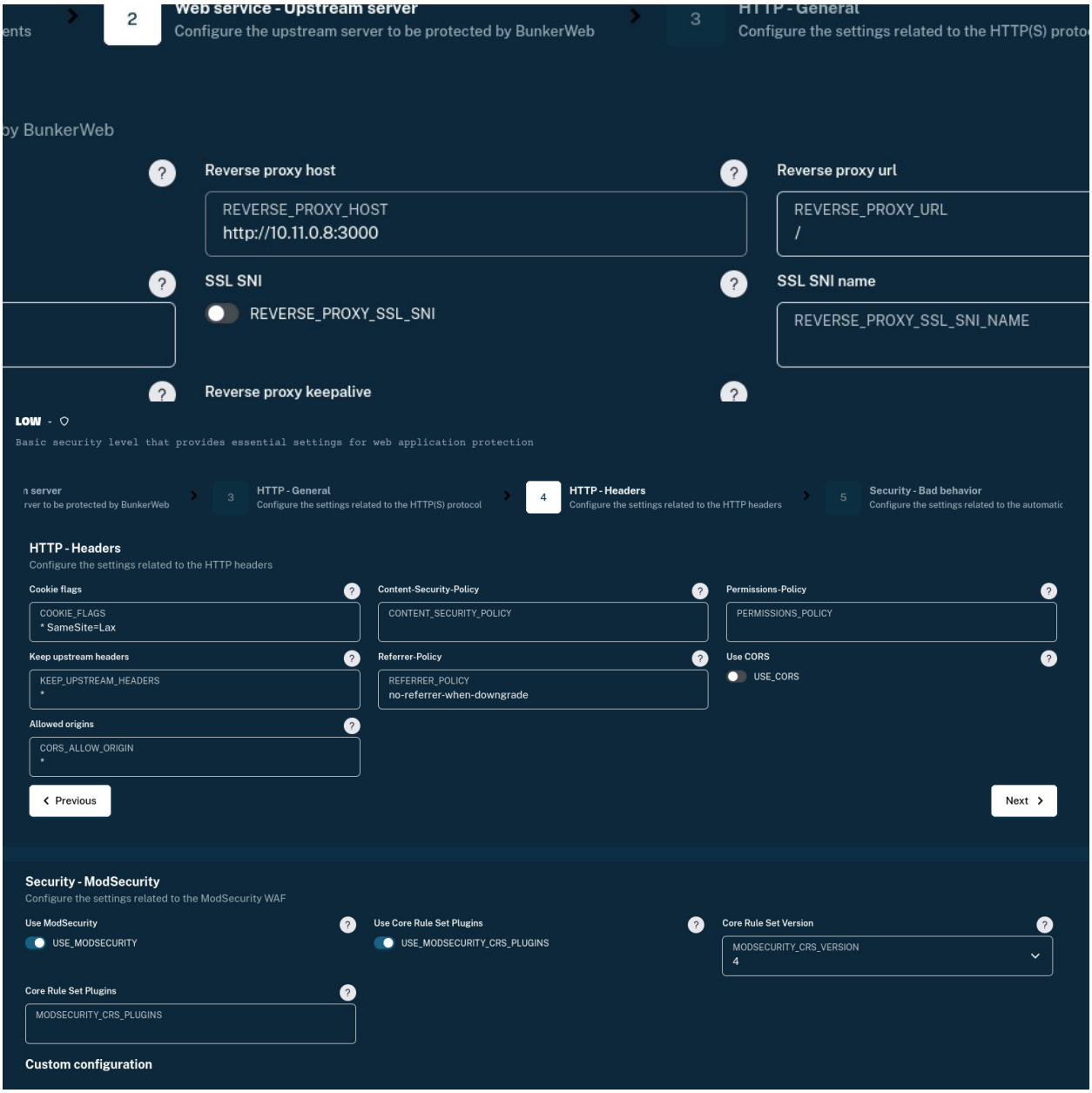
Внесите изменения в конфигурацию веб-приложения, которые позволяют устранить уязвимость — SQL-инъекцию.

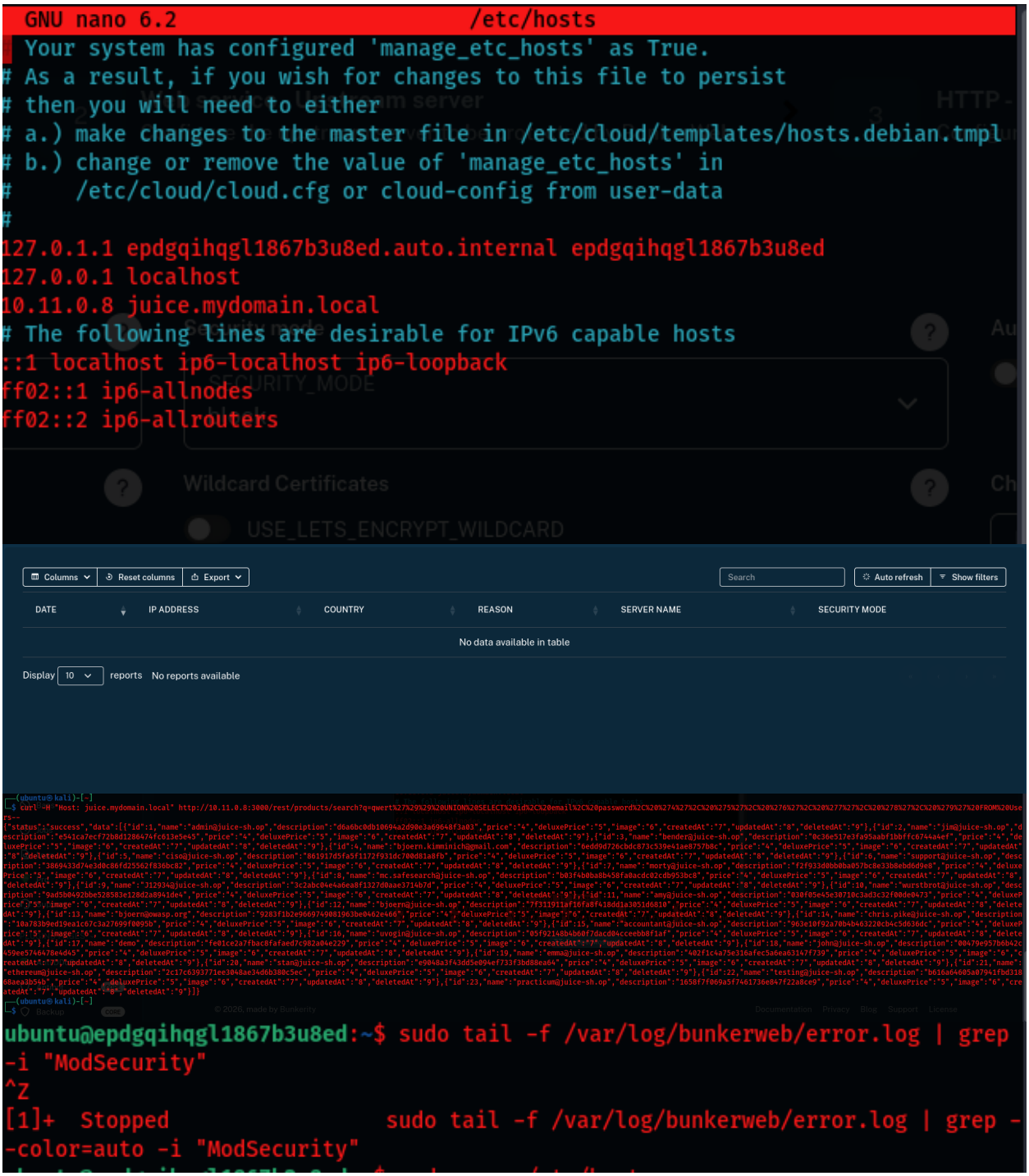
Invalid email or password

6. Настройка WAF

Установите и настройте файервол BunkerWeb. Включите защиту приложения от выполняемых ранее атак. Снова запустите брутфорс-атаку на пароль администратора или другого известного вам пользователя.




ents
2
Web service - Upstream server
Configure the upstream server to be protected by BunkerWeb
3
HTTP - General
Configure the settings related to the HTTP(S) proto
by BunkerWeb
Reverse proxy host
REVERSE_PROXY_HOST
http://10.11.0.8:3000
Reverse proxy url
REVERSE_PROXY_URL
/
SSL SNI
REVERSE_PROXY_SSL_SNI
SSL SNI name
REVERSE_PROXY_SSL_SNI_NAME
Reverse proxy keepalive
LOW -
Basic security level that provides essential settings for web application protection
n server
rver to be protected by BunkerWeb
3
HTTP - General
Configure the settings related to the HTTP(S) protocol
4
HTTP - Headers
Configure the settings related to the HTTP headers
5
Security - Bad behavior
Configure the settings related to the automatic
HTTP - Headers
Configure the settings related to the HTTP headers
Cookie flags
COOKIE_FLAGS
* SameSite=Lax
Content-Security-Policy
CONTENT_SECURITY_POLICY
Permissions-Policy
PERMISSIONS_POLICY
Keep upstream headers
KEEP_UPSTREAM_HEADERS
*
Referrer-Policy
REFERRER_POLICY
no-referrer-when-downgrade
Use CORS
USE_CORS
Allowed origins
CORS_ALLOW_ORIGIN
*
Previous
Next
Security - ModSecurity
Configure the settings related to the ModSecurity WAF
Use ModSecurity
USE_MODSECURITY
Use Core Rule Set Plugins
USE_MODSECURITY_CRS_PLUGINS
Core Rule Set Version
MODSECURITY_CRS_VERSION
4
Core Rule Set Plugins
MODSECURITY_CRS_PLUGINS
Custom configuration



Честно скажу, я долбался с ваерволом три часа, переустанавливал, настраивал, все по инструкции в уроке, это не заработало ни тогда не сейчас, я не зна. В чем проблем. В графе репортс и в логах ничего не пишется, хотя все включено и пингуется, и домен разрешается. Спрашивал у ИИ, у наставника, сбрасывал ВМ и настраивал заново, ему все равно, я увидел в уроке что должно быть в репортах, пожалуйста, господин ревьюер, не отправляй меня все переделывать, я потратил на это очень много времени и седлал все правильно, видимо какой то баг)))))))

Часть 4. Расследование сетевой активности

7. Загрузите подготовленный файл дампа трафика traffic.pcap. Откройте его в Wireshark и проведите анализ.

   В отчёте перечислите:

   - обнаруженные типы атак, их количество и результат;
   - IP-адреса и порты хоста, на котором расположены веб-приложения;
   - фильтры в Wireshark, позволяющие обнаружить аномалии.

   Сопоставьте атаки с техниками матрицы MITRE и предложите способы защиты приложения от них.

   Bruteforce атака - множество запросов с одного IP, в теле - wfuzz и ответы invalid password (http response code 200 нет, значит атака неуспешна) но дальше сразу была SQL успешная

   SQL-Injection - явно в теле запроса в строке email - sql

   Directory Bruteforce через gobuster

   Была иньекция команд, но не JUICE shop, а DVWA

   О методах защиты и матрице MITRE в части 2